

Incident Response Engagement Findings Report

INC-2026-008 - AD Reconnaissance & Kerberoasting

CLIENT

NexaCorp

Active Directory credential-access investigation

Engagement reference INC-2026-008

Investigation (Phase 1) + detection rule (Phase 2)

Prepared by

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi · github.com/Jhatchi

Date: 8 July 2026

Table of Contents

CONFIDENTIALITY STATEMENT	3
DISCLAIMER	3
EXECUTIVE SUMMARY	4
A. Introduction	4
B. Scope	4
C. Engagement summary	5
D. Overview of findings	6
E. Overview of recommendations	7
METHODOLOGY	8
A. Procedure	8
B. Severity Ratings	9
INVESTIGATION TECHNICAL SUMMARY	10
I1. Foothold via a real helpdesk account	10
I2. Active Directory enumeration	12
I3. Kerberoasting of svc_report	13
I4. SIEM detection gap	15
RISK MATRIX	16
MITRE ATT&CK MAPPING	17
DETECTION ENGINEERING (PHASE 2)	18
TOOLS AND STANDARDS	19
GLOSSARY AND ACRONYMS	21

Confidentiality Statement

This report documents Mission 08 of the BeCode Corp internal cybersecurity training programme, an incident response engagement conducted against a controlled laboratory environment simulating an Active Directory incident at the fictitious organisation NexaCorp. No real production system, customer data, or third-party infrastructure was targeted, accessed, or affected. All identities, hostnames and accounts referenced belong to the BeCode training environment and have no production analogue.

This document is classified as Internal - Not for distribution under reference BCC-2026 | INC-2026-008. Subject to that, the analyst retains the right to share this report as part of professional portfolios, certification evidence, and job applications, in line with the BeCode Corp policy on training deliverables.

Disclaimer

The findings and recommendations are based on the evidence package provided for INC-2026-008 (the domain controller Windows Security event log, Sysmon host telemetry, a Kerberos network capture, the Wazuh alert export, and the IT service-account register) covering the incident of 3 July 2026. The engagement has two deliverables: a Phase 1 investigation and this report, and a Phase 2 detection rule for the Wazuh SIEM. The methodology follows NIST SP 800-61r2 and the SANS PICERL process.

Executive Summary

A. Introduction

On the evening of Friday 3 July 2026, NexaCorp's domain controller logged a short, intense burst of directory queries followed by Kerberos service-ticket requests from a single internal workstation. The BeCode SOC team was tasked with establishing which account was used, what technique was applied against Active Directory, which credential is exposed as a result, and why the SIEM did not alert on the part that mattered. The engagement also delivers a Phase 2 detection rule to close that gap.

B. Scope

Target : the NexaCorp Windows domain nexacorp . lab, domain controller bru - dc - 01 (192.168.10.30), and the workstation bru - ws - 01 (192.168.10.31). Window : late June to 3 July 2026. Evidence : the DC Security event log, Sysmon host telemetry, a Kerberos network capture, the Wazuh alert export, and the IT service-account register. In scope : event-log and host-telemetry analysis, network-capture analysis, SIEM alert review, impact assessment, and a Phase 2 detection rule. Out of scope : live forensic acquisition, malware reverse engineering, offline password cracking.

C. Engagement summary

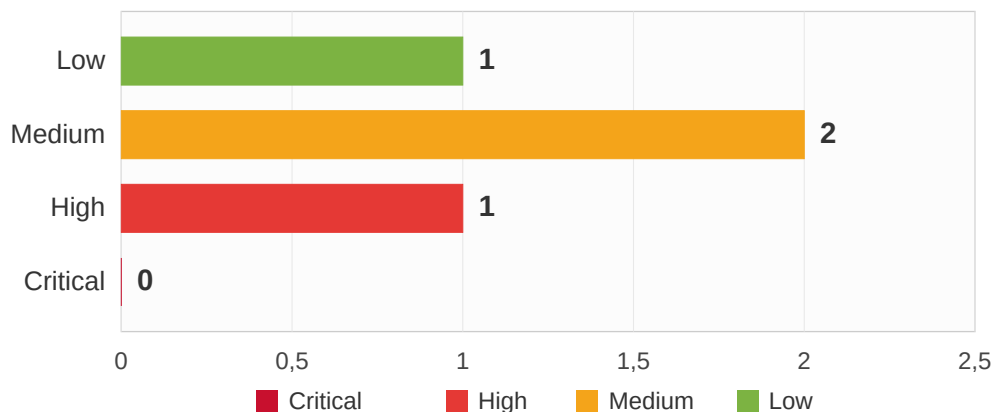
An attacker authenticated to the NexaCorp domain at 21:47:13 UTC as `t.remy`, a genuine helpdesk account, from the workstation `bru-ws-01`, outside that operator's working hours. The most plausible source of the credential is the employee directory exported during INC-2026-007: patching that flaw did not un-leak the data already taken. Within two minutes the session ran a heavy directory enumeration (40 directory-access events; SharpHound on the host), then at 21:58 UTC requested two Kerberos service tickets for the service account `svc_report`, both forced to the weak RC4 cipher.

The attacker did not break in with an exploit; they logged in and abused a normal feature of Kerberos. Any authenticated domain user may request a service ticket; the only thing that made this malicious was forcing RC4 (`ticketEncryptionType 0x17`) instead of modern AES, because an RC4 ticket can be cracked offline to recover the service account password. Of 2697 service-ticket requests in the window, only 2 used RC4, and both are this attack.

That single property is why the SIEM stayed silent on the part that mattered: of 25 Wazuh alerts that night, all concerned a noisy failed-logon burst from a different host, and none concerned the roast. The loud event was the decoy; the quiet event was the attack.

The overall posture is rated HIGH : a service-account credential is now exposed to offline cracking, a higher-value asset than the helpdesk login the attacker started with, and the pivot that sets up the next stage of a domain compromise. The most important point for management is that this was a logged-in abuse of a legitimate protocol feature, which is harder to see and harder to stop than a crashing exploit. Phase 2 of this engagement delivers the Wazuh rule (rule.id 100011) that detects this class of attack going forward.

Findings by Severity Level



B.

One finding reaches High severity: the Kerberoasting of `svc_report` (I3), which exposes a service-account credential to offline cracking. The assessment also identified **two Medium-severity findings** (I1, the out-of-hours foothold using the helpdesk account `t.remy`, and I2, the Active Directory enumeration with SharpHound) and **one Low-severity finding** (I4, the SIEM detection gap that left the roast unseen).

D. Overview of findings

Ref	Description	Severity
I1	Foothold via a real helpdesk account (t.remy), out of hours	MEDIUM
I2	Active Directory enumeration (SharpHound, 40 directory-access events)	MEDIUM
I3	Kerberoasting of svc_report (RC4 service ticket, offline-crackable)	HIGH
I4	SIEM blind to the Kerberoast (alerted only on a failed-logon decoy)	LOW

E. Overview of recommendations

REF	FINDING	SHORT RECOMMENDATION
I1	Foothold (t.remy)	Rotate t.remy now; alert on out-of-hours helpdesk logons and logons from unexpected workstations; MFA on reused accounts.
I2	AD enumeration	Alert on high-volume directory access (4662) from one source; detect SharpHound; adopt tiered administration.
I3	Kerberoasting	Rotate svc_report now; disable RC4 domain-wide (AES-only) and migrate service accounts to gMSA; deploy the Phase 2 rule.
I4	Detection gap	Deploy Wazuh rule 100011 (4769 + RC4) and a mass-roast correlation rule; detection and prevention are complementary.

Methodology

A. Procedure

The investigation follows NIST SP 800-61r2 (Computer Security Incident Handling Guide) and the SANS PICERL process, with a Phase 2 detection-engineering deliverable for the Wazuh SIEM.

01. Scope and evidence triage

- Validate the evidence bundle (DC Security log, Sysmon, Kerberos pcap, Wazuh export, SPN register)
- Confirm engagement boundaries



02. Signal isolation

- Profile the Event ID distribution across the Security log
- Break service-ticket requests down by encryption type to find the outlier



03. Attribution and timeline

- Group events by source host and account
- Reconstruct foothold, enumeration and roast; rule out the decoys



04. Target proof and impact

- Join the SPN register to the weak-cipher ticket to prove the targeted account
- Corroborate with host telemetry and the capture; assess the offline-crack consequence



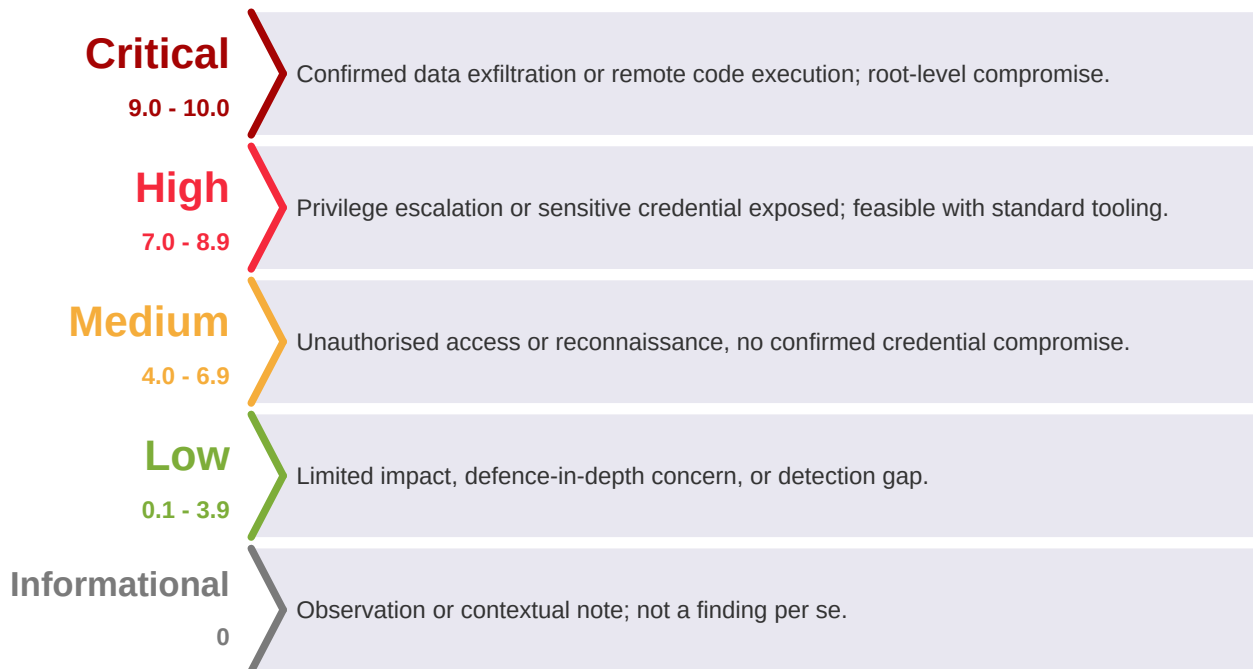
05. Detection gap and Phase 2 rule

- Review the Wazuh alerts (caught vs missed, and why)
- Author, submit and deploy the Wazuh detection rule



B. Severity Ratings

Severity uses the CVSS v3.1 base score as foundation, with engagement-contextual judgement where the consequence (an exposed service credential enabling further compromise) is the dominant factor.



Investigation Technical Summary

This section documents the four findings identified during the investigation. Each finding includes the affected scope, a CVSS-derived severity assessment, the technical description, evidence, and a remediation recommendation. The chain is one credential-access technique (Kerberoasting) preceded by a reconnaissance step, with a detection gap recorded as the fourth finding.

I1. Foothold via a real helpdesk account

Severity:

MEDIUM

Finding type:

Valid account abuse (foothold)

CVSS v3.1 base score:

6.5 (Medium) - AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

CWE:

CWE-284 (Improper Access Control)

MITRE ATT&CK:

T1078 (Valid Accounts)

Affected scope:

- Domain controller bru-dc-01 (192.168.10.30), account t.remy from bru-ws-01 (192.168.10.31)

Description:

The domain controller records a successful network logon (Event 4624, logon type 3) for t.remy at 21:47:13 UTC on 3 July 2026, originating from 192.168.10.31, whose workstationName resolves to bru-ws-01. The logon is outside that helpdesk operator's working hours. A Kerberos TGT request (Event 4768) precedes it by one second with normal AES encryption (0x12), so the account is genuine and nothing about obtaining the ticket is anomalous; the anomaly is who is using it, when, and what they do next.

The most plausible origin of the credential is the employee directory exported during INC-2026-007. Patching the IDOR flaw did not un-leak the 47 records that already escaped; knowing the usernames in use is exactly the intelligence that lets an attacker reuse a low-value helpdesk password.

Proof of evidence:

```
# DC Security log : out-of-hours network logon for t.remy from bru-ws-01
2026-07-03T21:47:12Z EventID=4768 targetUserName=t.remy ticketEncryptionType=0x12 (TGT,
AES)
2026-07-03T21:47:13Z EventID=4624 targetUserName=t.remy logonType=3 ipAddress=192.168.10.3
1 workstationName=bru-ws-01
```

Recommendation:

- **P1 - Rotate the temporary password** and review the account's access; treat the helpdesk credential as compromised.
- Alert on interactive or network logons by helpdesk accounts outside working hours, and on logons from unexpected workstations.
- Enforce phishing-resistant MFA / conditional access on accounts reused from leaked directories.

References and articles:

<https://attack.mitre.org/techniques/T1078/>

<https://cwe.mitre.org/data/definitions/284.html>

12. Active Directory enumeration (SharpHound)

Severity:

MEDIUM

Finding type:

Reconnaissance (directory enumeration)

CVSS v3.1 base score:

5.3 (Medium) - AV:N/AC:L/PR:L/UI:N/S:U/C:L/I:N/A:N

CWE:

CWE-200 (Exposure of Sensitive Information to an Unauthorized Actor)

MITRE ATT&CK:

T1087.002 (Account Discovery: Domain Account)

Affected scope:

- Domain controller bru-dc-01 (192.168.10.30) from bru-ws-01

Description:

Starting at 21:49:32 UTC, the same workstation generates 40 directory-access events (Event 4662) against the CN=Users container, far more than a normal interactive user produces. Host telemetry confirms the tooling: SharpHound.exe -c All was executed on bru-ws-01. This is the BloodHound data-collection step that maps users, groups and service accounts so the attacker can pick a worthwhile target. Enumeration on its own is not the attack, but here it is performed by the same identity and host that then request the malicious ticket, which is what separates it from a legitimate administrator's queries.

Proof of evidence:

```
# 40x directory-access events from the attacker host, then the tool on the workstation
2026-07-03T21:49:32Z EventID=4662 subjectUserName=t.remy objectName=CN=Users,DC=nexacorp,DC=lab (x40)
# Sysmon (process creation) on bru-ws-01
EventID=1 Image=SharpHound.exe CommandLine="SharpHound.exe -c All"
```

Recommendation:

- Alert on high-volume directory-access (Event 4662) and LDAP enumeration from a single non-administrative source.
- Deploy host detection for BloodHound collectors (SharpHound) and block known tooling where feasible.
- Adopt a tiered administration model so that directory metadata is not uniformly readable by every authenticated user.

References and articles:

<https://attack.mitre.org/techniques/T1087/002/>
<https://cwe.mitre.org/data/definitions/200.html>

13. Kerberoasting of the svc_report service account

Severity:

HIGH

Finding type:

Credential access (weak-cipher service ticket)

CVSS v3.1 base score:

8.1 (High) - AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:N/A:N

CWE:

CWE-326 (Inadequate Encryption Strength), CWE-294 (Authentication Bypass by Capture-replay)

MITRE ATT&CK:

T1558.003 (Steal or Forge Kerberos Tickets: Kerberoasting)

Affected scope:

- Service account svc_report (SPN HTTP/bru-app-01.nexacorp.lab), DC bru-dc-01

Description:

This is the core of the incident. At 21:58:03 and 21:58:07 UTC the domain controller issues two service tickets (Event 4769) for the service account svc_report, both with ticketEncryptionType = 0x17 (RC4-HMAC), requested from 192.168.10.31. The discriminator is decisive: across the evidence window the DC issued 2697 service tickets, of which 2695 used strong AES (0x12) and only 2 used weak RC4 (0x17). Both RC4 tickets belong to this attack, target the same account, and come from the attacker's workstation. An attacker forces RC4 specifically because an RC4 service ticket can be cracked offline to recover the account password (hashcat mode 13100).

Host telemetry names the tool: Rubeus.exe kerberoast /rc4opsec /nowrap /outfile:hash.txt; the /rc4opsec flag is what downgrades the request to RC4. The network capture corroborates this independently: a TGS-REQ for HTTP/bru-app-01.nexacorp.lab with etype 23 (RC4), which is the registered SPN of svc_report and joins the SPN register to the malicious ticket, proving which account was actually targeted.

Proof of evidence:

```
# The only two RC4 (0x17) service tickets, both for svc_report, from the attacker host
2026-07-03T21:58:03Z EventID=4769 serviceName=svc_report ticketEncryptionType=0x17 ipAddress=192.168.10.31
2026-07-03T21:58:07Z EventID=4769 serviceName=svc_report ticketEncryptionType=0x17 ipAddress=192.168.10.31
# Network capture : TGS-REQ for the targeted SPN with weak etype
192.168.10.31 -> 192.168.10.30 TGS-REQ SNameString=HTTP/bru-app-01.nexacorp.lab etype=23 (RC4)
```

Impact:

The attacker now holds an offline-crackable ticket for svc_report. Once cracked, they recover the service account's clear-text password without touching the network again: a new, higher-value credential

than the helpdesk login they started with, and the pivot that sets up the next stage of a domain compromise. Five domain accounts carry a registered SPN and are therefore eligible to be roasted (svc_report, svc_sql, svc_web, svc_mail, svc_backup_ad); only svc_report was actually attacked, but svc_backup_ad (a member of Backup Operators) is the highest-value roastable account and should be prioritised in hardening.

Recommendation:

- **P0 - Rotate the svc_report password now** and treat it as compromised; assume the ticket has been or will be cracked.
- **Remove the weakness class:** disable RC4 for Kerberos domain-wide (enforce AES) and migrate service accounts to group Managed Service Accounts (gMSA) with long, auto-rotated passwords.
- Deploy the Phase 2 Wazuh rule (rule.id 100011) that fires on any Event 4769 issued with RC4, and a correlation rule for a mass roast.

References and articles:

<https://attack.mitre.org/techniques/T1558/003/>

<https://cwe.mitre.org/data/definitions/326.html>

14. SIEM blind to the Kerberoast

Severity:

LOW

Finding type:

Detection coverage gap

CVSS v3.1 base score:

Low / Informational (no direct CVSS; defence-in-depth and monitoring concern)

CWE:

N/A (detection coverage)

MITRE ATT&CK:

N/A

Affected scope:

- Wazuh SIEM (manager monitoring the domain)

Description:

NexaCorp's Wazuh SIEM produced 25 alerts that night, all of them on a noisy failed-logon burst from a different host (192.168.10.66): 24 instances of rule 60122 (Logon failure) and one instance of rule 60204 (Multiple Windows logon failures from same source). It raised nothing on the Kerberoast, because a single service-ticket request (Event 4769) is, by itself, completely normal. The loud event was the decoy and the quiet event was the attack. This is the single most important detection lesson of the incident, and it is closed by the Phase 2 deliverable (see the Detection Engineering section).

Proof of evidence:

```
# Wazuh alerts that night : all on the failed-logon decoy, none on the roast
24 x rule 60122 level 5 Logon failure - Unknown user or bad password (src 192.168.10.66)
1 x rule 60204 level 10 Multiple Windows logon failures from same source
0 x on Event 4769 RC4 (the Kerberoast)
```

Recommendation:

- Deploy the Phase 2 Wazuh rule (rule.id 100011): fire on Event 4769 with ticketEncryptionType 0x17, keyed on the cipher rather than the account name so it catches any future roast.
- Add a correlation rule that escalates when one source requests several RC4 service tickets in a short window (mass roast).
- Remember that detection (the rule) and prevention (AES-only, gMSA) are complementary, not interchangeable.

References and articles:

<https://attack.mitre.org/techniques/T1558/003/>

Risk Matrix

The 5x5 matrix plots each finding by CVSS-derived Impact (vertical) against Likelihood (horizontal). The upper-right quadrant is the most urgent.

Impact / Likelihood	Very Low (1)	Low (2)	Medium (3)	High (4)	Very High (5)
Very High (5)					
High (4)				I3	
Medium (3)				I1	
Low (2)			I4	I2	
Very Low (1)					
Critical High Medium Low					

Top-right (most urgent) : I3 (Kerberoasting of svc_report), with I1 (foothold) and I2 (enumeration) feeding into it. Rotating the exposed credential, enforcing AES-only with gMSA, and deploying the Phase 2 rule closes the incident and the class of attack.

MITRE ATT&CK Mapping

Each finding is mapped to MITRE ATT&CK Enterprise techniques (v15). This incident is one primary technique (Kerberoasting) preceded by Account Discovery.

<i>Finding</i>	<i>Tactic</i>	<i>Technique ID</i>	<i>Technique Name</i>
I1	Initial Access / Persistence	T1078	Valid Accounts
I2	Discovery	T1087.002	Account Discovery: Domain Account
I3	Credential Access	T1558.003	Steal or Forge Kerberos Tickets: Kerberoasting
I4	Detection coverage	N/A	SIEM gap (no technique; monitoring finding)

Detection Engineering (Phase 2)

Phase 1 proved both the attack and that the SIEM said nothing about the part that mattered. Phase 2 closes that gap with a Wazuh rule. The detection idea is one sentence: a normal service-ticket request (Event 4769) is issued with strong AES encryption (0x11 / 0x12), while a Kerberoast deliberately forces the weak legacy RC4 cipher (0x17) so the ticket can be cracked offline, so a 4769 issued with RC4 is inherently suspicious. The rule keys on the encryption type, not the account name, so it catches any future roast rather than only svc_report.

The rule (deployed as rule.id 100011):

```
<rule id="100800" level="12">
  <if_group>windows</if_group>
  <field name="win.system.eventID">^4769$</field>
  <field name="win.eventdata.ticketEncryptionType">^0x17$</field>
  <description>Possible Kerberoasting: service ticket (4769) requested with weak RC4
  encryption</description>
  <mitre><id>T1558.003</id></mitre>
</rule>
```

Validation and tuning:

The rule was submitted to the lab Wazuh manager and deployed as rule.id 100011. In the incident evidence, exactly 2 of 2697 Event 4769 records used RC4 (0x17); the rule fires on those two and stays silent on the other 2695 AES (0x12) tickets, so it has no false positives on the normal service-ticket stream. If a site runs legacy services that legitimately negotiate RC4, they would be excluded explicitly via a documented list so the rule cannot drift.

Validated live: a controlled roast of all five SPN service accounts produced five rule.id 100011 alerts on the RC4 (0x17) Event 4769 records, and zero alerts on normal AES (0x12) service tickets, confirming the rule fires on the attack and stays silent on legitimate traffic.

A correlation rule (mass roast) extends the design: it escalates when one source IP requests several RC4 service tickets in a short window. Detection (this rule) and prevention (disable RC4 domain-wide, move service accounts to gMSA) are complementary controls: the rule catches the next roast, while AES-only plus gMSA removes the weakness entirely.

Tools and Standards

A. Tools Used During the Engagement

<i>Category</i>	<i>Tool</i>	<i>Purpose</i>
Event-log analysis	jq	Query and aggregate the Wazuh-format Security event export (Event ID distribution, encryption-type breakdown, per-host correlation)
Network capture analysis	tshark / Wireshark	Confirm the TGS-REQ for the targeted SPN and the RC4 etype
Decoding	base64 / python3	Decode an obfuscated PowerShell command in host telemetry
Log analysis	grep / sort / uniq	Triage and separate the attack from the failed-logon decoy
Detection	Wazuh	Author, submit and deploy the Phase 2 detection rule
Evidence retrieval	curl	Download the evidence bundle

B. Standards and Frameworks Followed

<i>Standard / Framework</i>	<i>Version</i>	<i>Application</i>
NIST SP 800-61r2	2012	Incident handling methodology
NIST SP 800-86	2006	Forensic technique integration / evidence handling
SANS PICERL	-	Incident response phases
MITRE ATT&CK Enterprise	v15	Technique mapping (T1087.002, T1558.003)
CVSS	v3.1	Severity scoring
CWE	v4.16	Root-cause classification
Wazuh	-	SIEM rule syntax for the Phase 2 deliverable

Glossary and Acronyms

<i>Acronym</i>	<i>Full Name</i>	<i>Description</i>
AD	Active Directory	Microsoft directory service that authenticates users, hosts and services in a Windows domain
DC	Domain Controller	Server that runs Active Directory and issues Kerberos tickets
Kerberos	Kerberos	The authentication protocol used by Active Directory
TGT	Ticket Granting Ticket	The initial Kerberos ticket proving a user authenticated (Event 4768)
TGS	Ticket Granting Service	The service-ticket exchange; requesting one is Event 4769
SPN	Service Principal Name	Identifier that binds a service to a domain account; required to be roastable
Kerberoasting	Kerberoasting	Requesting a weak-cipher service ticket to crack the service account password offline
RC4 / AES	Rivest Cipher 4 / Advanced Encryption Standard	Legacy weak vs modern strong Kerberos ticket encryption (0x17 vs 0x11/0x12)
gMSA	group Managed Service Account	Service account with a long, automatically rotated password, resistant to roasting
SIEM	Security Information and Event Management	Log aggregation and correlation platform (here, Wazuh)
SOC	Security Operations Center	Team responsible for security monitoring and response
IOC	Indicator of Compromise	Artifact pointing to malicious activity
MITRE ATT&CK	Adversarial Tactics, Techniques and Common Knowledge	Threat behaviour framework
PCAP	Packet Capture	Captured network traffic
UTC / CEST	Coordinated Universal Time / Central European Summer Time	Time references used in this report

BeCode Corp.

DFIR / SOC Training

Reference: BCC-2026 | INC-2026-008

Classification: Internal - Not for distribution

Analyst

Johan-Emmanuel Hatchi

BeCode Cybersecurity Bootcamp - Promotion 2025-2026

linkedin.com/in/johan-emmanuel-hatchi

github.com/Jhatchi